

Analisi dei Rischi: Prescrizioni (Fascicolo Sanitario Elettronico)

1. Identificazione degli Asset

Per la specifica delle prescrizioni, l'asset primario da proteggere è il Documento XML della Prescrizione (PrF/PrS).

I requisiti di sicurezza fondamentali applicati sono:

- **Riservatezza:** I dati del paziente e la patologia/farmaco non devono essere esposti.
- **Integrità:** Il contenuto della prescrizione non deve subire alterazioni.
- **Disponibilità:** Il sistema deve permettere la prescrizione rapida e la trasmissione al Sistema TS.
- **Non Ripudio:** Il medico non deve poter disconoscere la prescrizione emessa.

2. Valutazione degli Eventi (Scala 1-5)

E1 - Alterazione dei Dati di Prescrizione (Integrità): Modifica accidentale o malevola del file XML (es. codice AIC del farmaco) prima della firma o durante il transito in rete.

*Probabilità: 3 (Media) | Impatto: 5 (Catastrofico) → **Rischio: 15 (Alto)***

E2 - Disconoscimento della Prescrizione (Non Ripudio): Un medico nega di aver effettuato una prescrizione o falsificazione dell'ID prescrittore.

*Probabilità: 2 (Bassa) | Impatto: 5 (Catastrofico) → **Rischio: 10 (Medio-Alto)***

E3 - Accesso Non Autorizzato ai Dati Sanitari (Riservatezza): Personale non autorizzato accede al database o intercetta file XML in chiaro contenenti patologie e terapie.

*Probabilità: 3 (Media) | Impatto: 5 (Catastrofico) → **Rischio: 15 (Alto)***

E4 - Interruzione del Servizio di Prescrizione (Disponibilità): Impossibilità di generare l'XML o inviarlo al Sistema TS a causa di un down della rete ospedaliera.

*Probabilità: 3 (Media) | Impatto: 4 (Grave) → **Rischio: 12 (Alto)***

E5 - Fallimento del Processo di Conservazione Sostitutiva: L'outsourcer perde i file PDF/XML o si verificano errori nel software di versamento interno, perdendo il valore legale nel tempo.

*Probabilità: 2 (Bassa) | Impatto: 4 (Grave) → **Rischio: 8 (Medio)***

E6 - Furto o Smarrimento Dispositivo Edge: Un tablet o un terminale mobile usato in corsia viene rubato o smarrito, esponendo file temporanei o sessioni attive.

*Probabilità: 3 (Media) | Impatto: 5 (Catastrofico) → **Rischio: 15 (Alto)***

E7 - Data Breach presso il Conservatore Esterno: Il provider in outsourcing subisce un attacco informatico o un dipendente infedele accede ai Pacchetti di Archiviazione (PdA).

*Probabilità: 2 (Bassa) | Impatto: 5 (Catastrofico) → **Rischio: 10 (Medio-Alto)***

3. Matrice di Rischio 5x5

Impatto (Gravità)	Probabilità				
	1 (Molto Bassa)	2 (Bassa)	3 (Media)	4 (Alta)	5 (Molto Alta)
5 (Catastrofico)		E2, E7 (10)	E1, E3, E6 (15)		
4 (Grave)		E5 (8)	E4 (12)		
3 (Moderato)					
2 (Modesto)					
1 (Trascurabile)					

4. Legenda degli Eventi e Misure di Gestione

RISCHIO ALTO (Intervento Immediato Richiesto)

• E1 - Alterazione dei Dati di Prescrizione (Integrità):

- **Azione Preventiva:** Implementazione di un workflow rigoroso di Firma Digitale Elettronica Qualificata (FEQ) in formato XAdES prima dell'invio al Sistema TS.
- **Azione Deterrente:** Timeout automatico e rapido delle sessioni sui terminali in corsia per evitare session hijacking.

• E3 - Accesso Non Autorizzato ai Dati Sanitari (Riservatezza):

- **Azione Preventiva:** Cifratura del database (Encryption at Rest), trasmissione tramite canali sicuri (TLS 1.2/1.3) e rigido Controllo degli Accessi Basato sui Ruoli (RBAC).
- **Azione Mitigativa:** Anonimizzazione/Pseudonimizzazione (es. con OpenAIRE Amnesia) dei dati prima di usarli per test o ricerca.

• E4 - Interruzione del Servizio di Prescrizione (Disponibilità):

- **Azione Preventiva:** Architettura di rete ridondata per le comunicazioni tra ambulatori, corsie e sala macchine.
- **Azione di Ripristino:** Sistema di caching locale per salvare le prescrizioni offline e inviarle in differita al ritorno della connessione.

• E6 - Furto o Smarrimento Dispositivo Edge (Riservatezza):

- **Azione Preventiva:** Cifratura completa del disco (Full Disk Encryption) del dispositivo e timeout di sessione molto aggressivo.
- **Azione Correttiva:** Sistema MDM (Mobile Device Management) per il wipe (cancellazione) da remoto del dispositivo non appena ne viene segnalata la scomparsa.

● RISCHIO MEDIO (Mitigazione e Monitoraggio)

• E2 - Disconoscimento della Prescrizione (Non Ripudio):

- **Azione Preventiva:** Uso obbligatorio di smartcard personale non cedibile per l'autenticazione al sistema di prescrizione.
- **Azione Deterrente:** Tracciamento inalterabile (log) dei metadati di sistema (IP, orario, terminale) associati a ogni firma apposta.

• E5 - Fallimento del Processo di Conservazione Sostitutiva (Conformità):

- **Azione Preventiva:** Validazione rigida degli XML tramite schema (XSD) prima della generazione del pacchetto di versamento verso l'outsourcer.
- **Azione Correttiva:** Backup locale temporaneo dei documenti fino alla ricezione formale della "Ricevuta di Presa in Carico" da parte del conservatore; SLA contrattuali stringenti.

• E7 - Data Breach presso il Conservatore Esterno (Riservatezza):

- **Azione Preventiva:** Accordi legali stringenti (DPA - Data Processing Agreement) e, soprattutto a livello tecnico, l'invio dei dati all'interno del Pacchetto di Versamento in una "busta" crittografica (es. cifratura del file compresso prima dell'invio al sistema esterno), in modo che l'outsourcer conservi i dati a norma ma non possa leggerne i contenuti in chiaro senza l'autorizzazione dell'AO.